FLASK

1. Business Context

Organisation Overview

Greenfield Local Hub (GLH) is a cooperative of local farmers and food producers. They run a single shop that sells locally made food and drink. What makes GLH different from a normal shop is that the producers all share the retail space and marketing costs together, and they have a system that lets customers trace where their food came from. The three main things GLH does are sell products directly to customers, do shared marketing for its members, and keep track of where every product comes from.

Current Systems and Processes

Right now GLH only has its physical shop and things like social media and word-of-mouth to reach customers. If a producer needs to tell GLH about a stock change, they do it by phone, email, or even a paper note. This creates a lot of extra work for the staff because there is no central system keeping everything in one place. Customers also have no way of checking what is in stock before they travel to the shop, which means they might make a wasted trip.

Problems With the Current System

There is no way for customers to pre-order or place orders online at all. Everything is manual and paper-based, which means GLH cannot grow easily, cannot manage stock well across multiple producers, and cannot offer the kind of ordering options that customers expect today. It also means GLH has no reliable sales data to work from, which makes it hard to make good business decisions.

Industry Context

The food retail sector has moved heavily towards online and hybrid ordering, where customers can either get delivery or click-and-collect. Competitors like Riverford and Oddbox have set the standard for what customers expect. Research shows that 67% of consumers say online ordering is essential when choosing a food retailer (Mintel, 2024), and demand for traceable food is still growing (Soil Association, 2023). If GLH does not have a digital solution, it risks losing customers to those competitors.

Stakeholders and User Types

There are three types of users in this system. Each one has different needs and a different level of access. Role-based access control (RBAC) is enforced on the server side so each user can only get to the parts of the system they are supposed to.

Customer	Browse and purchase local produce, track orders, manage account, earn and redeem loyalty points	View items, basket and checkout, order tracking, account dashboard, loyalty scheme, accessibility features	Public pages (unauthenticated), authenticated customer routes only
Producer	Manage product listings, update stock levels in real time, view and process incoming orders, monitor sales performance	Producer dashboard, product CRUD (Create, Read, Update, Delete), stock overview (RAG indicators), order queue, sales summary	Authenticated producer routes only; data isolation (can only see own products/orders)
Administrator	Oversee solution operations, manage user accounts, approve new producer registrations, monitor stock alerts and the order pipeline, and access sales analytics.	Access a centralised dashboard providing solution-wide metrics, user management tools, producer approval workflows, low-stock alerts, and full order oversight.	Authenticated admin routes with full read/write access across all solution data

Purpose of the Proposed Solution

The solution we are building will support all three of GLH's main goals — retail, collective marketing, and product traceability — inside a single web application. The three user types above have been used to shape the functional requirements and the problem decomposition later in this proposal.

Functional requirements:

Functional requirements describe what users need to be able to do in the system. Each one below is linked to something the client asked for in the brief. I have given each one a priority using MoSCoW so it is clear what needs to be built first.

ID	Requirement	Description	Priority	Justification
FR01	**User Registration and Login**	Users register with name, email and password. System validates inputs, hashes password using Werkzeug, sends email verification. Login checks hash and creates a session cookie. Logout clears the session.	**Must Have**	GLH needs to know who each user is so it can personalise orders, save account history, and control what each role can access. Without login, the loyalty scheme and order history cannot work.
FR02	**Product Catalogue Browsing**	Customers can view a paginated list of all products from all GLH producers. Each product shows the name, image, price, availability badge and producer name. Filters (category, producer, price range, availability) update the results without reloading the whole page.	**Must Have**	This directly addresses the brief requirement to show products with transparent pricing and availability. The catalogue is the main way customers find and buy things.

FR03	**Product Detail and Traceability**	Each product page shows price, live stock status, a link to the producer profile, farming method, origin, allergen information (FIC compliance), certifications and customer reviews.	**Must Have**	This covers GLH's traceability objective and the brief requirement to provide information about producers and their methods. Customers can see exactly where their food came from.
FR04	**Basket Management**	Customers can add, remove, and change quantities in their basket. The basket is stored server-side, not just in the browser. It re-checks stock when checkout starts to catch any purchases that happened at the same time.	**Must Have**	Storing the basket server-side means customers do not lose it if they close the browser. The stock re-check stops a customer checking out with something that has just sold out.
FR05	**Checkout with Delivery or Collection**	Multi-step checkout where customers pick delivery (enter address, postcode used to work out shipping) or collection (choose from a time-slot calendar). Payment is handled by Stripe and an order record is created.	**Must Have**	The brief specifically asks for orders to support both collection and delivery. The time-slot calendar lets GLH manage how many orders it can handle each day.
FR06	**Order History**	Customers can see all their past orders with the date, items, total, fulfilment method and final status. Clicking an order shows the full breakdown.	**Must Have**	The brief asks for account management and order history. Customers need to be able to check what they have ordered and sort out any issues.
FR07	**Real-Time Order Tracking**	Customers can see where their order is on a status timeline (Placed → Picked → Packed → Dispatched or Ready for Collection). The page checks for updates every 10 seconds using AJAX so the status changes without a full page refresh.	**Must Have**	The brief's market research said order tracking is a priority for customers. Showing live updates means fewer customers ringing GLH to ask where their order is.
FR08	**Producer Product Management**	Producers can add, edit and delete their own product listings from the dashboard. The form includes name, description, category, price, up to 3 images, farming method, allergen flags, and certifications. Inputs are validated on both the client side and server side.	**Must Have**	The brief asks for a dashboard that lets producers update product details. Validating on both sides means bad data cannot get into the database even if the client-side check is skipped.
FR09	**Producer Stock Management**	Producers can update stock levels for each product. Changes show up straight away in the customer catalogue. A RAG system shows green when stock is above the threshold, amber when it is low, and red (Out of Stock) when it hits zero.	**Must Have**	The brief asks for producers to manage stock. Keeping the dashboard and the catalogue in sync in real time stops customers from adding out-of-stock items to their basket.
FR10	**Producer Order Management**	Producers can view all orders that include their products, filtered by status. They can update the status (Picked, Packed, Ready/Dispatched), and each update sends an	**Must Have**	The brief asks for producers to view orders. The status updates the producer makes are what drives the order tracking feature (FR07) on the customer side.

		automated notification to the customer.		
FR11	**Administrator Dashboard**	Admin can see platform-wide metrics like total orders, revenue, stock alerts, and user registrations. They can manage all accounts and approve new producer registrations.	**Must Have**	GLH needs visibility across the whole cooperative. The producer approval step means only verified producers can list products in the catalogue.
FR12	**Loyalty Scheme**	Points are awarded when an order is completed (5 points per £5 spent). Points can be redeemed at checkout for discounts (100 points = £1 off). Admin can configure special offers with start and end dates.	Should Have	The brief's market research said a loyalty scheme was a desired feature. Loyalty schemes encourage customers to come back and spend more.
FR13	**Order Scheduling**	Customers pick a delivery date or collection time slot during checkout. Admin can set how many orders each slot can take. The calendar shows which slots still have space.	Should Have	The brief says scheduling is a desired feature. Time slots help GLH plan its fulfilment workload and reduce missed or late deliveries.
FR14	**Accessibility Features**	Font size can be adjusted (small, medium, large), there is a high-contrast mode toggle, all elements are keyboard-navigable, ARIA markup is used throughout, and there are skip-navigation links. Preferences are saved to the user account.	**Must Have**	The brief asks for accessibility features. The Equality Act 2010 also makes this a legal requirement, especially for GLH's older customer base.
FR15	**Informational Content — Benefits of Buying Local**	A dedicated content section with articles on the environmental, economic and health benefits of buying locally. Individual producer profile pages include a farm location map, biography, and farming method.	Should Have	The brief asks the solution to explain the benefits of buying locally and to provide information about producers and their methods. This content supports GLH's collective marketing goal.

Non-functional requirements

Non-functional requirements describe how the system should behave rather than what it should do. They cover things like speed, security, and accessibility. If these are not met, the system might technically work but still be unusable or unsafe.

Category	Requirement	Description	Justification
Performance	**Page Load Time**	All main pages (catalogue, product detail, checkout, dashboard) must load within 3 seconds on a standard connection. Google Lighthouse score must be 80 or above.	Google's research shows that 53% of mobile users leave a page if it takes more than 3 seconds to load. A slow catalogue directly means fewer orders.
Performance	**Database Query Response**	All API endpoints must respond within 500ms under normal load. Tables that get queried a lot (Products, Orders) must use indexed columns.	Features like AJAX stock polling and order tracking only feel smooth if the back-end responds quickly. Unindexed queries get significantly slower as the database grows.
Scalability	**Concurrent Users**	The system must handle 300 users at the same time without slowing down. Flask is served through Gunicorn with multiple workers, and SQLite is set to WAL (Write-Ahead Logging) mode to handle concurrent reads and writes.	GLH will have busy periods during seasonal events. WAL mode in SQLite allows reads and writes to happen at the same time without locking the whole database, which is enough for a cooperative of this size.
Security	**Encryption in Transit**	All data between the browser and server must use HTTPS/TLS 1.2 or higher. HTTP requests are automatically redirected to HTTPS, and HSTS is set.	UK GDPR Article 32 requires appropriate technical security measures. Without HTTPS, customer addresses, session tokens and order data could be intercepted.
Security	**Input Sanitisation**	All user inputs are sanitised server-side before touching the database. The sqlite3 library uses parameterised queries (? placeholders) throughout. No raw SQL string building is allowed.	SQL injection is in the OWASP Top 10. A single unsanitised input could expose or delete the entire database. Parameterised queries prevent this by treating all user input as data, not SQL.
Security	**Authentication**	Passwords are hashed using Werkzeug's generate_password_hash before being stored. Session cookies are signed with Flask's SECRET_KEY. Failed login attempts are rate-limited to 5 per minute per IP.	Werkzeug's hashing is resistant to brute-force and rainbow table attacks. Rate limiting stops automated tools from trying thousands of passwords. Signed cookies mean session data cannot be tampered with.
Reliability	**Uptime**	The system must be available at least 99.5% of the time, measured monthly. Maintenance must only happen between 02:00 and 04:00.	If the system is down, producers cannot update stock and customers cannot order. 99.5% uptime allows about 3.6 hours of downtime per month, which is enough for small maintenance tasks.
Accessibility	**WCAG 2.1 AA**	All pages must pass a WCAG 2.1 Level AA automated audit (axe-core) with no critical violations. Text contrast must	The Equality Act 2010 requires reasonable adjustments for disabled users. GLH's customer base includes older users who

		be at least 4.5:1. All interactive elements must work with a keyboard alone.	may use screen readers or rely on keyboard navigation.
Compatibility	**Cross-Browser / Responsive**	The site must fully work on Chrome, Firefox, Safari and Edge (latest 2 versions each). The layout must work from 320px (small mobile) up to 2560px (large desktop).	More than half of UK e-commerce traffic comes from mobile devices. If the site breaks on a phone or in a particular browser, those customers cannot buy anything.
Maintainability	**Code Quality**	Python follows PEP 8. All functions have docstrings. JavaScript uses camelCase. CSS follows BEM naming. Everything is version-controlled in Git with meaningful commit messages.	GLH will need updates as it adds more producers. Well-organised code is much easier and cheaper to maintain over time. Task 2 will also be assessed on code quality.
Data Integrity	**Transactional Writes**	Stock decrements and loyalty point deductions happen inside SQLite transactions. If anything goes wrong, the whole transaction rolls back.	Without transactions, two customers buying the last item at the same time could both get a confirmation, which means GLH has to disappoint one of them. Transactions prevent this.

Problem decomposition:

I have split the GLH platform into three main parts — the front-end (what the user sees), the back-end (the logic that runs on the server), and the database (where everything is stored). Keeping these separate means I can work on or fix one part without accidentally breaking the others.

To keep the HTML clean and avoid repeating code, I am using Jinja2 block templates and template inheritance. This means I build one base.html file that has the shared layout — the navigation bar, the footer, and the page structure. Every other page then just extends that base and fills in its own content block. So if the navigation bar needs changing, I only have to edit one file instead of every single page.

The front-end is what all three user types interact with directly. Bootstrap handles the responsive layout so the site works on mobile and desktop without me writing separate CSS for every screen size. JavaScript adds the dynamic features that make things feel smooth — filtering the catalogue without a page reload, polling for order status updates every 10 seconds, and stepping through the checkout. Chart.js draws the sales bar chart on the producer dashboard, which gives farmers a quick visual of how their products are selling without having to read through a table of numbers.

The back-end handles all the logic. Authentication is done in Python using Werkzeug's generate_password_hash and check_password_hash functions, which means passwords are never stored as plain text. Flask controls which users can access which routes using decorators — a customer cannot open a producer URL and a producer cannot open the admin panel, even if they try typing the URL directly. Stripe is used for payments, which means GLH never touches card data at all. This removes the biggest PCI-DSS obligations from the application.

The database is SQLite, accessed through Python's built-in sqlite3 library. A relational database makes sense here because the data is all connected — an order links a customer to multiple products from multiple producers, each with their own stock level. SQLite's serialised write locking means only one write transaction can happen at a time, which solves the problem of two customers buying the last item simultaneously. Security is not something added on at the end — parameterised queries, Werkzeug password hashing, Jinja2 autoescape, and Flask-WTF CSRF tokens are all part of how each component works from the start.

Front-End Components

Component	Description	Technology / Approach

User Interface — Customer Shop	Displays product catalogue, product detail pages with traceability information, basket, multi-step checkout and order tracking timeline. Responsive layout across all screen sizes using Bootstrap's grid system.	HTML5, Bootstrap 5 (grid, components, utilities), CSS for custom overrides, JavaScript (Fetch API for AJAX, DOM manipulation). Jinja2 block templates extend a shared base layout so navigation and footer are defined once.
User Interface — Producer Dashboard	Tabbed interface: product CRUD form, stock RAG indicators, order queue, sales summary chart. Each tab loads without a full page reload.	HTML5, Bootstrap 5 (nav tabs, cards, tables), JavaScript (tab switching, Chart.js for sales bar chart, Fetch API for stock updates).
User Interface — Admin Panel	Solution metrics cards, user management table, producer approval queue, low-stock alerts. Data-dense layout optimised for scanning.	HTML5, Bootstrap 5 (grid, table, badge components), JavaScript (inline search/filter on user management table).
Jinja2 Block Templates	A single base.html defines the page structure, navigation bar and footer. All other pages extend this using Jinja2 {% block %} tags. This means a change to the nav only needs to be made in one place.	Jinja2 templating engine (built into Flask). {% extends %}, {% block %}, {% include %} tags throughout. Template inheritance enforces consistent layout across all pages.
Client-Side Form Validation	Instant field-level error feedback on all forms before submission. Reduces server round-trips and improves experience for non-technical producers filling in product forms.	JavaScript (HTML5 Constraint Validation API + custom messages), Bootstrap validation classes (is-invalid, invalid-feedback). Server-side validation via Flask and Werkzeug is the authoritative check.

Back-End Components

Component	Description	Technology / Approach
User Authentication and RBAC	Handles registration (Werkzeug password hashing), login (hash verification, session cookie), session validation and logout. Role-based access control enforced on every protected route via Flask decorators — not just hidden in the UI.	Python, Flask, Werkzeug (generate_password_hash / check_password_hash), Flask session (signed cookie). @login_required and role-check decorators on all protected routes.
Product and Stock API	CRUD endpoints for product management. Werkzeug handles file uploads securely (secure_filename). Server-side validates all inputs before any database write.	Python, Flask, sqlite3 library. Parameterised ? placeholders throughout — no string-building in SQL.
Order Processing Engine	Validates basket against live stock, decrements stock inside a SQLite transaction, creates order and line-item records, renders confirmation via Jinja2 template. Handles collection (time-slot allocation) and delivery (address entry).	Python, Flask, sqlite3 (BEGIN / COMMIT / ROLLBACK), Jinja2 for confirmation page.
Loyalty Engine	Awards points on order completion (not placement, to prevent earning on cancelled orders). Reserves points at checkout start to prevent double-spending. Special offer discounts configurable by admin.	Python, Flask, sqlite3 atomic transactions. Idempotency guard in SQL: INSERT OR IGNORE on the earned-points record prevents duplicate awards.
Payment Service	Creates a payment record and integrates with Stripe. Stripe.js	Python, Stripe Python SDK, Flask route for Stripe webhook. GLH's

	renders card input in a hosted iframe — card data never reaches GLH's server. Werkzeug validates the webhook signature.	SQLite database stores only the Stripe PaymentIntent ID, never card data.

Database and Integration Components

Component	Description	Technology / Approach
Relational Database Schema	Stores users, products, stock levels, orders, order items, order status log, loyalty balances, loyalty transactions, time slots and payments. Designed to Third Normal Form to eliminate redundancy.	SQLite (via Python sqlite3 library). schema.sql file defines all tables, constraints and indexes. Foreign key enforcement enabled explicitly with PRAGMA foreign_keys = ON at connection start.
Transactional Stock Control	Stock decrements performed inside a SQLite transaction. Checks stock immediately before decrement within the same transaction. Rolls back on any failure, preventing overselling when two customers attempt to buy the last unit simultaneously.	Python sqlite3 with BEGIN / COMMIT / ROLLBACK. SQLite's serialised write locking means only one write transaction proceeds at a time, which solves the race condition without needing row-level locks.
Security Measures	Passwords hashed with Werkzeug before storage — plaintext never written to the database. All SQL uses parameterised ? placeholders — no string interpolation. Flask secret key signs session cookies to prevent tampering. Jinja2 autoescapes all template variables by default, blocking XSS.	Werkzeug security module, Python sqlite3 parameterised queries, Jinja2 autoescape, Flask session (signed with SECRET_KEY), Flask-WTF CSRF tokens on all POST forms.
Jinja2 Template Rendering	Flask renders all HTML responses server-side using Jinja2. The base.html block template defines the shared layout; child templates only define the content specific to that page. This keeps the codebase DRY and ensures consistent structure across all 20+ pages.	Jinja2 (Flask built-in). render_template() in every Flask route. {% extends 'base.html' %} in every child template.
Stripe Payment Integration	Offloads all card data handling to Stripe. GLH's SQLite database stores only the Stripe PaymentIntent ID — never card numbers, CVV codes or expiry dates. Removes PCI-DSS card data obligations from the application entirely.	Stripe Python SDK, Flask webhook route. Werkzeug used to verify webhook signature header.

Section 6 — KPIs and User Acceptance Criteria

KPIs give GLH measurable targets to check whether the solution is actually working after it goes live. They are SMART — Specific, Measurable, Achievable, Realistic and Time-bound. User Acceptance Criteria (UAC) describe the specific things each type of user must be able to do for the solution to be signed off as fit for purpose.

Performance	Average page load time	Under 3 seconds	Google Lighthouse audit on homepage, catalogue, product detail, checkout, and producer dashboard. All must score 80 or above for performance.
Reliability	System uptime	99.5% or more each month	UptimeRobot checks every minute. Monthly report shared with GLH admin. Any incidents are logged with a root cause.
Customer — Registration	UAC-C1: Customer registers and logs in	Done in under 3 minutes	Tester registers with valid data, confirmation email arrives, login works, and they are redirected to the customer dashboard.
Customer — Browse	UAC-C2: Catalogue filters work	Correct results, no page reload	Tester applies category and availability filters at the same time. Only matching in-stock products appear. The page does not reload.
Customer — Checkout	Checkout success rate / UAC-C3	97% or above; checkout completes correctly	Database ratio: orders placed divided by checkouts started. Tester places a collection order with a time slot. Order appears in the database and a confirmation email arrives within 2 minutes.
Customer — Tracking	UAC-C4: Order status updates in real time	Visible within 10 seconds	Producer updates status to Packed. Customer goes to the tracking page. New status shows within 10 seconds.
Customer — Loyalty	Loyalty engagement / UAC-C5	40% or more of repeat customers redeem within 3 months; discount applied correctly	LoyaltyTransactions query for redemption rate. Tester earns points on a purchase, applies them at next checkout, and the correct £ discount comes off the total.
Customer — Accessibility	UAC-C6: Mobile usability	All journeys work at 375px viewport	Tester browses, checks out, and views account on a 375px viewport. No horizontal scrolling. All tap targets are at least 44px. Font size controls work.
Producer — Auth	UAC-P1: Data stays isolated between producers	HTTP 403 on any cross-producer attempt	Producer A logs in and tries to access Producer B's product URL directly. Gets a 403. No data from Producer B appears anywhere on the page.
Producer — Products	UAC-P2: New product appears in catalogue	Visible within 5 seconds of saving	Producer fills in the add-product form with all required fields. Product appears in the customer catalogue. A customer tester can add it to their basket.

Producer — Stock	Stock accuracy / UAC-P3: No overselling	Zero overselling; Out of Stock shows instantly	Database query checks for orders where quantity is more than stock at the time. Producer sets stock to 0. Customer reloads product page. Out of Stock badge shows and Add to Basket is disabled.
Producer — Dashboard	Producer dashboard adoption	85% of producers update stock each week	Admin analytics: last_stock_update timestamp per producer. Weekly report generated.
Security	No critical security vulnerabilities	0 critical issues on OWASP ZAP scan	OWASP ZAP scan run against the staging environment before go-live. All critical and high findings fixed. Scan repeated after every major update.
Accessibility	WCAG 2.1 AA compliance	Zero critical violations on axe-core	axe-core automated audit on all page templates. Manual keyboard navigation test. NVDA screen-reader test on checkout and registration.
Customer Satisfaction	Post-order satisfaction rating	Average 4.2 out of 5 or above	In-app star rating shown 24 hours after delivery or collection is confirmed. Results stored in a Ratings table and shown on the admin dashboard.

KPIs give GLH measurable targets to check whether the solution is actually working after it goes live. They are SMART — Specific, Measurable, Achievable, Realistic and Time-bound. User Acceptance Criteria (UAC) describe the specific things each type of user must be able to do for the solution to be signed off as fit for purpose.

Area	KPI / UAC	Target / Condition	How It Is Measured / Tested
Performance	Average page load time	Under 3 seconds	Google Lighthouse audit on homepage, catalogue, product detail, checkout, and producer dashboard. All must score 80 or above for performance.
Reliability	System uptime	99.5% or more each month	UptimeRobot checks every minute. Monthly report shared with GLH admin. Any incidents are logged with a root cause.
Customer — Registration	UAC-C1: Customer registers and logs in	Done in under 3 minutes	Tester registers with valid data, confirmation email arrives, login works, and they are redirected to the customer dashboard.
Customer — Browse	UAC-C2: Catalogue filters work	Correct results, no page reload	Tester applies category and availability filters at the same time. Only matching in-stock products appear. The page does not reload.
Customer — Checkout	Checkout success rate / UAC-C3	97% or above; checkout completes correctly	Database ratio: orders placed divided by checkouts started. Tester places a collection order with a time slot. Order appears in the database and a confirmation email arrives within 2 minutes.
Customer — Tracking	UAC-C4: Order status updates in real time	Visible within 10 seconds	Producer updates status to Packed. Customer goes to the tracking page. New status shows within 10 seconds.
Customer — Loyalty	Loyalty engagement / UAC-C5	40% or more of repeat customers redeem within 3 months; discount applied correctly	LoyaltyTransactions query for redemption rate. Tester earns points on a purchase, applies them at next checkout, and the correct £ discount comes off the total.
Customer — Accessibility	UAC-C6: Mobile usability	All journeys work at 375px viewport	Tester browses, checks out, and views account on a 375px viewport. No horizontal scrolling. All tap targets are at least 44px. Font size controls work.
Producer — Auth	UAC-P1: Data stays isolated between producers	HTTP 403 on any cross-producer attempt	Producer A logs in and tries to access Producer B's product URL directly. Gets a 403. No data from Producer B appears anywhere on the page.
Producer — Products	UAC-P2: New product appears in catalogue	Visible within 5 seconds of saving	Producer fills in the add-product form with all required fields. Product appears in the customer catalogue. A customer tester can add it to their basket.
Producer — Stock	Stock accuracy / UAC-P3: No overselling	Zero overselling; Out of Stock shows instantly	Database query checks for orders where quantity is more than stock at the time. Producer sets stock to 0. Customer reloads product page.

			Out of Stock badge shows and Add to Basket is disabled.
Producer — Dashboard	Producer dashboard adoption	85% of producers update stock each week	Admin analytics: last_stock_update timestamp per producer. Weekly report generated.
Security	No critical security vulnerabilities	0 critical issues on OWASP ZAP scan	OWASP ZAP scan run against the staging environment before go-live. All critical and high findings fixed. Scan repeated after every major update.
Accessibility	WCAG 2.1 AA compliance	Zero critical violations on axe-core	axe-core automated audit on all page templates. Manual keyboard navigation test. NVDA screen-reader test on checkout and registration.
Customer Satisfaction	Post-order satisfaction rating	Average 4.2 out of 5 or above	In-app star rating shown 24 hours after delivery or collection is confirmed. Results stored in a Ratings table and shown on the admin dashboard.

Section 8 — Risks and Mitigation

Because GLH handles personal data, food products, and online payments, there are several laws and standards that the solution needs to comply with. I have listed each one below along with what it requires and how the solution addresses it.

Regulation / Standard	What It Requires	How the Solution Addresses It
UK GDPR (2021) and Data Protection Act 2018	Personal data must only be collected where it is needed (data minimisation). Customers must be told what is collected, why, and for how long. They have the right to access, correct, and delete their data. Marketing emails need explicit opt-in consent.	Privacy policy is accessible from every page. The registration form has a separate opt-in checkbox for marketing — pre-ticked boxes are not used. Customers can download or delete their data from their account. Retention periods are defined per data type (for example, orders are kept 7 years for tax; inactive accounts deleted after 3 years).
Consumer Rights Act 2015 and Consumer Contracts Regulations 2013	Product descriptions must match the goods. Customers have a 14-day right to cancel for distance sales. Order confirmations are legally binding contracts. The refund policy must be shown before payment.	Producers are responsible for their descriptions and images. Any inaccurate listing is flagged to admin. Cancellation rights, returns policy, and refund steps are shown on the checkout page and in the customer account. The confirmation email counts as the contract and includes a 14-day cancellation link.
Food Information to Consumers (FIC) Regulation 2014	The 14 major allergens must be listed and highlighted on all food products. Origin must be shown for certain fresh produce. Net weight and unit price must be visible.	The producer's add-product form has mandatory checkboxes for all 14 allergens. Allergens are displayed clearly on the product detail page. The origin field is mandatory for fresh produce categories. Net weight and price-per-unit are required fields.
Payment Card Industry Data Security Standard (PCI-DSS)	Any business taking card payments must either comply with PCI-DSS or use a certified third-party processor.	All payments are handled by Stripe, which is a PCI-DSS Level 1 certified provider. The card input field is rendered inside a Stripe-hosted iframe using Stripe.js — card numbers, CVV codes, and expiry dates never pass through GLH's server or database. The SQLite

		database only stores the Stripe PaymentIntent ID.
WCAG 2.1 Level AA	Digital services should be accessible to users with disabilities. WCAG 2.1 AA is the accepted standard and links to the Equality Act 2010.	Colour contrast is at least 4.5:1 throughout. All images have alt text. All forms have proper labels. All interactive elements work with a keyboard. ARIA landmark roles and labels are used on dynamic content. An axe-core audit and manual keyboard and screen-reader tests will run before launch.
Copyright, Designs and Patents Act 1988	All assets used (images, fonts, code libraries) must be owned, licensed for commercial use, or open-source with a compatible licence.	An assets log is kept throughout development that records the source and licence of every third-party asset. Only CC0, CC-BY, royalty-free, or open-source assets are used. Producer-submitted images stay the property of the producer; GLH holds a licence to display them, as stated in the producer terms of service.
Privacy and Electronic Communications Regulations (PECR) 2003	Cookie consent must be collected before setting non-essential cookies. A cookie policy must explain each cookie's purpose, duration, and whether it is shared with third parties.	A cookie consent banner appears on the first visit to any page. Session management cookies are set without consent as they are strictly necessary. Analytics and preference cookies are only set after explicit opt-in. The cookie policy page lists every cookie by name, purpose, duration, and third-party status.

Emerging technologies

Current Technologies in the Retail Food and Produce Sector

Responsive Web Design	More than 50% of UK e-commerce traffic now comes from mobile devices (IMRG, 2023). Platforms like Riverford and Oddbox use responsive layouts so one codebase works on any screen size.	Bootstrap 5 is used to create a layout that adapts from 320px on a small phone up to 2560px on a large desktop. The mobile-first approach means the most constrained screen is designed first and extra features are added for larger screens.
Real-Time Inventory Management	Major retailers like Ocado keep their digital storefronts in sync with warehouse stock in real time. Farm-box services update availability as produce is picked and packed.	AJAX polling on the product detail page checks live stock status every 30 seconds. When a producer updates stock in the dashboard, it writes to the SQLite database immediately and is reflected to any customer viewing that product. If stock hits zero, the Add to Basket button is disabled straight away.

Payment APIs	Stripe, PayPal and Apple Pay are standard for UK food e-commerce. Customers expect a checkout experience that feels familiar and trustworthy.	Stripe.js provides the payment form inside a hosted iframe. Apple Pay and Google Pay are supported through Stripe's Payment Request Button at no extra integration cost. Stripe handles all PCI-DSS compliance.
Order Scheduling and Time-Slot Management	Click-and-collect with time slots is now standard at Tesco, Waitrose and Ocado. Customers expect to pick a specific window rather than a vague estimate.	A time-slot calendar is built into the checkout. GLH admin can set the number of orders allowed per slot. Booked slots are recorded in the TimeSlots table and the calendar shows remaining capacity. Producers see the scheduled fulfilment date in their order queue.
Product Traceability via Digital Records	The Food Standards Agency and major supermarkets increasingly require farm-to-fork traceability. QR codes and digital records are becoming standard.	Each product stores a full traceability chain: producer, farm location, farming method, harvest date (optional), and certifications. This is shown on the product detail page and directly supports GLH's traceability objective.

Emerging Technologies — Future Development

Emerging Technology	What It Is and Why It Matters	How GLH Could Use It
AI-Driven Stock Prediction	Machine learning models can be trained on past sales data to forecast demand by product, season, and day of the week. Retailers like Waitrose and Tesco already use this to reduce food waste and prevent stock-outs.	A future version of the producer dashboard could show AI-generated demand predictions for the next two to four weeks, warning producers to increase stock before a spike. This would reduce both stock-outs and overproduction waste, which fits with GLH's environmental values.
Delivery Route Optimisation	Route optimisation algorithms (like Google Maps Routes API or the open-source OR-Tools library) calculate the most efficient delivery order for multiple drop-off points, saving fuel and time.	If GLH expands into home delivery, a route optimisation service could automatically plan each driver's route based on the day's orders. This would lower GLH's carbon footprint and cut delivery costs, which both align with the cooperative's local and sustainable identity.
QR Code Product Traceability	QR codes on product labels, when scanned by a smartphone, link directly to a product page showing the full provenance chain. The GS1 standard for QR traceability is being rolled out across UK supermarkets.	GLH could generate QR codes for producer labels from within the platform. Scanning the code would open the product detail page showing the producer, harvest date, farming method, and certifications. This extends traceability beyond the digital checkout into the physical product itself.
Progressive Web App (PWA) Capabilities	PWAs use service workers to cache content locally so the app can load and work partially offline. They can also be added to a phone's home screen like a native app, without going through an app store.	A service worker added to the GLH platform would let customers in rural areas with patchy connectivity still browse the catalogue offline using cached data. It could be installed on a home screen to increase repeat visits, without the cost and complexity of building separate iOS and Android apps.

Regulation / Standard	Requirement and Application to GLH	Implementation in the Solution
UK GDPR (2021) and Data Protection Act 2018	Personal data (names, emails, delivery addresses, order history, loyalty points) must be collected only where necessary (data minimisation — Article 5). Customers must be informed of what data is collected, why, for how long, and their rights (Articles 13–14). Rights to access, rectify and erase data must be supported (Articles 15–17). Marketing communications require explicit opt-in consent (Article 7).	Privacy policy accessible from all pages. Registration form includes separate opt-in checkbox for marketing emails (pre-ticked opt-out boxes prohibited). Account area provides self-service data download and deletion requests. Data retention periods defined per data type (e.g. order records retained 7 years for tax purposes; inactive accounts deleted after 3 years). DPA Article 30 record of processing activities maintained by GLH admin.
Consumer Rights Act 2015 and Consumer Contracts Regulations 2013	Product descriptions must accurately represent the goods sold. Consumers have 14-day cancellation rights for distance sales. Digital order confirmations constitute binding contracts. Refund policy must be clearly stated before purchase.	All product descriptions and images are sourced from and verified by the producer; any materially inaccurate listing flagged to admin. Cancellation rights, returns policy and refund procedure displayed on checkout page and in customer account. Order confirmation email constitutes the contract and includes a cancellation link valid for 14 days.
Food Information to Consumers (FIC) Regulation 2014	The 14 major allergens must be identified and highlighted for all food products. Country or region of origin must be stated for fresh meat, fish and certain fresh produce. Net weight and unit pricing must be shown.	Product creation form in the producer dashboard includes mandatory allergen flag checkboxes for all 14 allergens. Allergens are displayed prominently on the product detail page with bold formatting. Origin field is mandatory for fresh produce categories. Net weight and price-per-unit are mandatory fields.
Payment Card Industry Data Security Standard (PCI-DSS)	Merchants processing card payments must comply with PCI-DSS or use a compliant third-party processor. Non-compliance can	All payment processing delegated entirely to Stripe (PCI-DSS Level 1 Service Provider). GLH's solution uses

	result in fines and loss of card processing rights.	Stripe.js, which renders the card input form inside a Stripe-hosted iframe. Card numbers, CVV codes and expiry dates never pass through GLH's servers or database. GLH stores only the Stripe PaymentIntent ID for reference.
Web Content Accessibility Guidelines (WCAG) 2.1 Level AA	Digital services should be accessible to users with disabilities. WCAG 2.1 AA is the accepted standard and aligns with the Equality Act 2010 reasonable adjustment obligations.	Colour contrast ≥ 4.5:1 throughout. All images include meaningful alt text. All forms have associated labels. All interactive elements operable by keyboard. ARIA landmark roles (main, nav, aside) and ARIA labels on dynamic content. Error messages programmatically associated with the relevant form field. Automated axe-core audit run on all page templates; manual keyboard and NVDA screen-reader testing before launch.
Copyright, Designs and Patents Act 1988	All digital assets (images, text, fonts, code libraries) used in the solution must either be owned by GLH, licensed for commercial use, or open-source with a compatible licence.	Assets log maintained throughout development recording source, licence type and permitted use for every third-party asset. Only Creative Commons (CC0 or CC-BY), royalty-free or open-source licensed assets used. Producer-submitted images remain the intellectual property of the producer; GLH holds a licence to display them on the solution (stated in producer terms of service).
Privacy and Electronic Communications Regulations (PECR) 2003	Cookie consent must be obtained before setting non-essential cookies. A cookie policy must explain each cookie's purpose, duration and whether it is shared with third parties.	Cookie consent banner displayed on first visit to all pages. Essential session management cookies set without consent (strictly necessary). Analytics cookies (if used) and preference cookies set only after explicit opt-in. Cookie policy page

		details each cookie's name, purpose, duration and third-party status.

Section 11 — Wider Issues